

1. Nmap Scan Report Analysis (20 Marks)

Scenario: Nmap scan on 192.168.1.10 identified open ports SSH (22), HTTP (80), and MySQL (3306), along with the operating system and service versions.

Security Risks

HTTP (80): Plain-text communication, vulnerable to sniffing, SQL Injection, XSS, directory traversal, and remote file inclusion.

SSH (22): Weak passwords, brute-force attacks, credential theft, and outdated SSH vulnerabilities.

MySQL (3306): Database exposure, weak credentials, privilege escalation, SQL Injection, and data theft.

OS and Service Versions: Version detection helps attackers identify known vulnerabilities.

Security Recommendations

Use HTTPS, deploy a WAF, disable SSH root login, enable key-based authentication and MFA, restrict MySQL access, use strong passwords, update all software, configure firewalls, enable IDS/IPS, and perform regular vulnerability assessments.

Conclusion: Proper hardening, patching, and access control reduce the attack surface.

2. GoPhish Report Analysis (20 Marks)

Scenario: 40% clicked phishing links, 20% entered credentials, and several downloaded malicious attachments.

Security Weaknesses

High click rate indicates poor phishing awareness. Credential submission shows trust in fake login pages. Downloading malicious attachments exposes systems to malware and ransomware.

Possible Attacks

Credential theft, business email compromise, ransomware, spyware, unauthorized access, and lateral movement.

Recommendations

Conduct regular awareness training and phishing simulations, enforce strong passwords, enable MFA, deploy spam filters, attachment sandboxing, URL filtering, SPF, DKIM, DMARC, and establish clear security policies.

Conclusion: Employee awareness and strong email security controls significantly reduce phishing risks.

3. DNS Zone Transfer (AXFR) Analysis (10 Marks)

Scenario: Dig assessment revealed that the DNS server allows AXFR, exposing internal hostnames, mail servers, DNS records, and IP addresses.

Security Implications

Attackers can perform reconnaissance, identify critical systems, launch targeted attacks, create convincing phishing campaigns, scan for vulnerabilities, and move laterally after compromise.

Best Practices

Disable public AXFR, restrict transfers using ACLs, allow only authorized secondary DNS servers, enable DNSSEC, keep DNS software updated, monitor DNS logs, and perform periodic DNS security audits.

Conclusion: Restricting DNS zone transfers and implementing DNS security best practices protects sensitive infrastructure information.